



Cybersecurity Handbook

Management of Cybersecurity requirements and the secure development process, as well as the documentation of relevant information in the development of security-related products

Documentheader

Document name:	Cybersecurity Handbook	
Status:	APPROVED	
Created:	31. März 2025	M.Schmidt
last change:	20. Aug. 2025	M.Schmidt
last review	7. Juli 2025	
approval:	29. Sept. 2025	TUEV Rheinland

Content

Cybersecurity Part 1 – Introduction

Foreword

Introduction

Security strategy

Cybersecurity Culture

Cybersecurity Strategy

Cybersecurity goals

Enterprise

Management and Leadership

Employees and collaboration

Communication

Project development and project start

Project planning

Project controlling

Risk management

Change Management

Supply Chain Management

Test and validation management

Cybersecurity Part-2 - Cyber Security Plan, Integration into Development Processes

Introduction

Overview of product development or product life cycle phases

Organizational / Project-Specific

Requirements and management

Development process

Identification of responsibilities

Cybersecurity expertise

Process containment

File integrity

IT security of the development environment

Private Key Monitoring

Cybersecurity Requirements of Externally Deployed Components

Customer-specific components from third-party suppliers

Assessing and addressing security-related issues

Process Verification

Continuous improvement

Product Cybersecurity Lifecycle

Design phase

Cybersecurity environment of the product

Threat modeling

Cybersecurity requirements for the product

Requirements for the Cybersecurity environment of the product

Overview of Cybersecurity requirements

Development and testing

Principles for a secure design

Design of a Defense-in-Depth Concept

Cybersecurity Design Review

Secured Design Best Practices

Verified Implementation

Coding standards for Cybersecurity

Examination of Cybersecurity requirements

Threat mitigation testing

Vulnerability Testing

Penetration Testing

Independence of the tester

Suitability of Cybersecurity updates

Documentation of Cybersecurity updates

Documentation of Cybersecurity updates for dependent components or operating systems
Delivery of Cybersecurity updates
Timely delivery of Cybersecurity patches
Provisioning
Cybersecurity Policies
Review of documentation
Operation, continuous monitoring and maintenance
Initiation of Periodic Review
Mapping table for product life cycle and standards
List of abbreviations

Cybersecurity Part 1 – Introduction

Foreword

The manual describes the general requirements for management when considering Cybersecurity in product development. The scope of this manual covers the entire product life cycle from the idea to decommissioning. For each phase of the life cycle, different areas of action are defined and associated measures are explained or described. In addition, Part Two describes activities that must be taken into account in the development process.

 The term "Cybersecurity" is intentionally used in this document. The use of the term safety may lead to unintended analogies to the domain of "functional safety" and thus cause incorrect conclusions or misunderstandings. Furthermore, the US-American spelling is preferred.

Introduction

In addition to the E2E Security Guideline, the strategic decision was made in December 2020 to take the challenges of Cybersecurity into account when developing products. In the past, it has been shown that the IEC EN 62443 series of standards is authoritative and defines the technical requirements for Cybersecurity in the stationary automation industry and formulates necessary organizational requirements for component manufacturers, integrators and operators. From the component manufacturer's point of view, two sections of the above-mentioned series of standards are important. IEC EN 62443-4-1 defines the requirements for the product life cycle, whereas IEC EN 62443-4-2 defines the functional requirements for the components based on the security level to be achieved. Parallel to the stationary automation industry, ISO SAE 21434 has established itself as the de-facto standard in mobile automation. The ISO SAE 21434 standard is used to meet the growing challenges posed by the increasing networking, automation and digitalization of vehicles. This serves the goal of meeting the requirements of UNECE R155. The aim of this handbook is to specify the requirements for Cybersecurity as simply as possible and to enable practicable and targeted decisions to be taken. This document

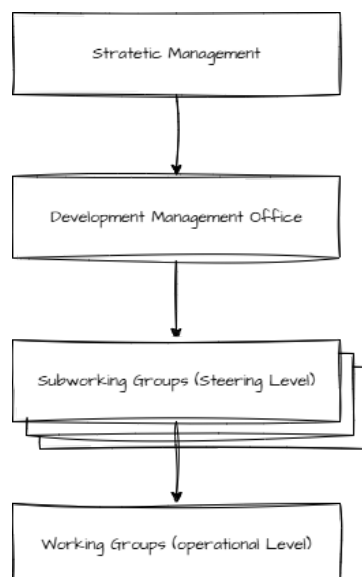
defines requirements that ensure the most stable and consistent Cybersecurity level possible over the entire life cycle of a product.

The Cybersecurity Handbook is intended to help people involved in product development to implement the necessary measures effectively and verifiably. The handbook is intended to support day-to-day work and provide detailed information and recommendations for action on the respective project phases. In addition, the handbook contains references to further detailed information, templates and recommendations for action. In the treatment of Cybersecurity requirements, the requirements of IEC EN 62443-4-1 and ISO SAE 21434 are considered simultaneously.

Security strategy

The ifm strategy for Cybersecurity requires a uniform awareness. By integrating Cybersecurity-specific challenges into the established development processes, a comprehensive and trustworthy implementation can be achieved. Through cross-divisional cooperation, ifm can develop uniform approaches in the field of Cybersecurity and thus reduce the additional effort of each individual. The aim is to develop and apply global, uniform, implementation standards and procedures.

For this purpose, strategic guidelines and procedures are centrally specified via the Security Sub-Working Group (SWG Security). SWG is represented by the Cybersecurity Manager. The client for SWG's work is the central DMO (Development Management Office) of the ifm group of companies. The strategic guidelines and the procedures serve as a work assignment for the Cybersecurity Technical Working Group (AK Cybersecurity). The Working Group Cybersecurity develops and publishes the global, uniform technical implementations of Cybersecurity for all product groups.



It should be noted that Cybersecurity must be taken into account in all life cycles of all product groups. The extent to which functional requirements must be met will be explained below. The aim of ifm is to keep the targeted level of security constant over the entire product life cycle, as far as technically possible. In the long term, an open vulnerability culture and active Cybersecurity awareness are to be established.

The following table provides an overview of the distributed organizations for each Cybersecurity responsibility.

Tasks - Distributio n of Roles (RACI Matrix)	Cyberse curity Manager	Cybersec urity Engineer	Technica l Manage ment	Worki ng group Secur ity	Outsourc ing- Mgmt or purchasi ng Dep.	Informati on Security	DMO Subwork ing group Security	Global Security Services
Strategy & Governan ce	R	C		C		C	A	
Roles & Responsib ilities			R					
Cybersec urity Managem ent System (CSMS)		I				R		
Risk managem ent	I	R						
Requirem ents managem ent			R					
Project Coordinati		R						

on								
Technical security measures	C			R				
Security Testing & Validation		R						
Incident Response & Monitoring	A	C	I					R
Training & Awareness	R							
Compliance & Audits	C		R					
Supplier Management	C				R			
Lifecycle Security			R					

Cybersecurity Culture

In addition to the purely technical aspects of Cybersecurity, which make it possible to integrate products into a customer's own security concept in the first place, various cultural factors play a decisive role in establishing a robust and entrepreneurial Cybersecurity strategy.

Cybersecurity Strategy

A Cybersecurity strategy exists within the ifm Group. All Cybersecurity decisions, measures and goals are based on this one Cybersecurity strategy. The Cybersecurity strategy presented includes the requirements for ifm's products and solutions, other areas such as IT or production are not within the scope of this strategy.

Cybersecurity goals

The aim of the Cybersecurity strategy is a uniform and consistent implementation of the necessary measures in all products of the ifm Group. The following basic protection objectives are required, where applicable.

Confidentiality Protection

of sensitive information from unauthorized access – e.g. operational data, passwords or configuration files.

Integrity Ensuring

that data and system functions are not altered without authorization – they should remain accurate and trustworthy.

Availability systems

and data must be available at all times, especially for time-critical industrial processes.

Actions

in the system must be able to be clearly traced back to users or systems – e.g. by logging.

Authenticity Ensuring

that users, devices, and data sources are genuine and trustworthy – protecting against identity forgery.

Non-repudiation Ensuring

that actions or transactions carried out cannot be disputed afterwards – e.g. through digital signatures.

Enterprise

The ifm Group integrates the requirements of Cybersecurity into the value chain. Necessary adjustments but also necessary investments will be carried out.

In order to meet the growing requirements of Cybersecurity, the company continuously invests in the further development and development of employees. This includes the development of the necessary specialist expertise as well as the establishment of the necessary organizational structures and specialists.

The aim is to develop the entire company, but individual further education and training should also help to cope with the psychological aspects of Cybersecurity in the best possible way.

Management and Leadership

The challenge of Cybersecurity can only be overcome if managers recognize, actively support and promote its importance. Open and clear communication about Cybersecurity policies and practices helps with decision-making.

Employees and collaboration

Each member of the team contributes to the overall Cybersecurity concept in the product. The discovery of weaknesses or problems is pursued openly and constructively. Every vulnerability or other Cybersecurity incident is discussed and dealt with in the team without negative consequences from colleagues or managers. Any vulnerability or bug is used to avoid future repetition. Insights are shared within the group of companies and thus lead to an overall improvement of all products and solutions.

Through interdivisional cooperation, best practices are developed and made available to all development teams.

An open and constructive error culture and the open handling of weak points, both internally and externally, supports a cooperative partnership between suppliers, companies and customers. A violation or misuse of this information inevitably leads to damage to one's own company and a loss of trust with competitors.

Violating these principles or concealing/concealing vulnerabilities can lead to personal disciplinary measures, as Cybersecurity is part of the European Union's Declaration of Conformity (CE Declaration) and a prerequisite for approval of the product.

 Ensuring competence is a fundamental activity of the ifm innovation process.

Communication

The area of communication coincides with the definition in the Project Management Handbook (PjM-Handbuch). In addition, there is a bilateral exchange between the ifm development teams. The advantage of this approach is that the participants can carry out a constant exchange of information. Open and constructive communication should be emphasized. This applies to internal cross-divisional communication as well as externally to suppliers and customers.

 When passing on information, both within the company and externally, ifm's own information classification must be observed, see [Classification Guideline](#)

Project development and project start

The development of secure products, like any project, begins with the creation of the requirement specification. The challenge is that security-related factors are rarely defined in connection with the customer's business needs. Under certain circumstances, it may happen that we as a component manufacturer cannot clearly define the intended use of the article to be developed and thus it is not possible to determine the necessary Security level. If no or incomplete information about the use and purpose of use is available, generic information is used, on a customer project basis or from comparison of competitions. If the contracting

authority has not defined any specific requirements (definition PJM item 5.1.1), a basic level of Security is assumed. Basic Cybersecurity results from previous projects or products with similar characteristics. Basically, a risk-based approach is used to determine Cybersecurity requirements. The resulting security requirements from the above-mentioned procedures are included in the specifications. The documentation is carried out in addition to the content specifications already specified in the PJM. The transfer of the requirements formulated in the requirement specification to the functional specification takes place via the description. In the PJM. In the area of Cybersecurity, the challenge of product maintenance is an elementary building block. As already described, products must be considered in terms of security functionalities over the entire product life cycle. This requirement will make it necessary to initiate a product maintenance project in the event of a vulnerability (see PJM 5.7.2.2). If availability, integrity or confidentiality is endangered by a known vulnerability, appropriate efforts must be made to implement measures that eliminate the said vulnerability but do not affect other functions of the article. It is important here that a new risk analysis is carried out when the software is changed. This is to prevent the adaptation of a software component from creating new, previously unconsidered risks. Under certain circumstances, it may be necessary to take compensatory measures on the customer side to prevent exploitation of the vulnerability. This case occurs, e.g. if the article has no possibility to weaken or eliminate the vulnerability itself by adapting or updating it.

 The risk-based approach is preferable to freely accepting requirements or reusing them.

Project planning

See Chapter 6 Project Management Manual

Project controlling

See Chapter 7 Project Management Manual

Risk management

Apart from the functional risk analysis in the requirement engineering or in the system design phase, no special requirements are placed on the risk management of the project.

Change Management

If changes are necessary in the development phase of the article, it is important that an adapted threat and risk analysis is carried out for each change. This is to prevent changes (e.g. adding another communication protocol) to the article from leading to security problems. Decisions about adjustments or changes in the development project are approved by the respective project change control board.

Supply Chain Management

In order to secure supplier components, it must be ensured that all necessary Security measures are observed. This means that all components are sourced from trusted and well-known sources. The manufacturer must provide information about its own vulnerability management. In addition, the communication channels for the receipt of reports must be agreed. Since ifm is also a supplier, this claim also applies. This means that ifm has a responsibility to provide open information about known vulnerabilities and to provide appropriate recommendations for action.

Test and validation management

In test and validation management, the area of Cybersecurity is subject to the same requirements. Ensuring that the requirements are implemented in a targeted and correct manner remains the goal of this requirement.

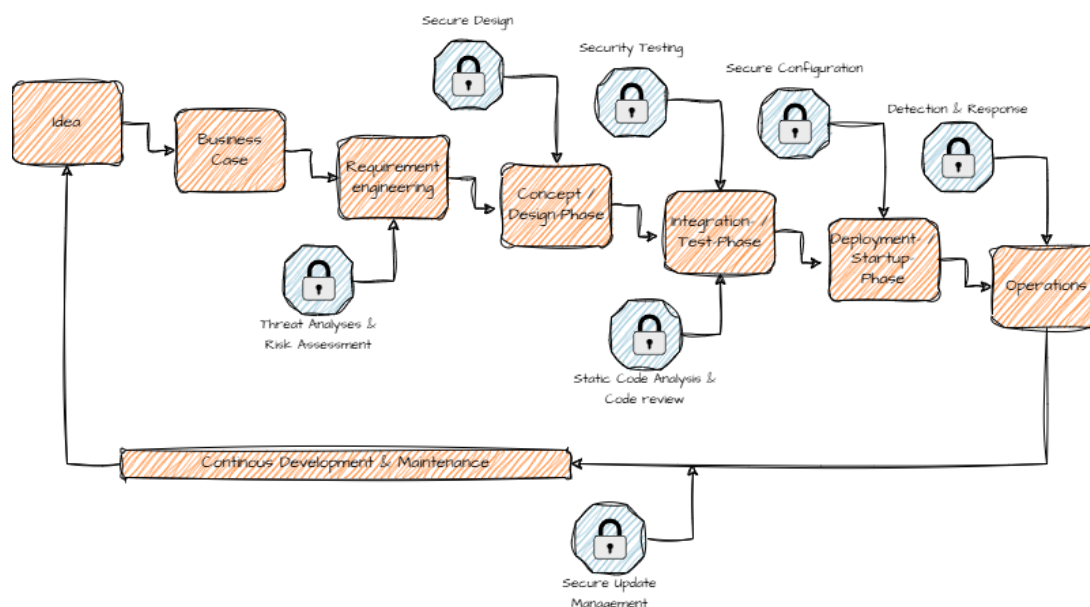
Cybersecurity Part-2 - Cyber Security Plan, Integration into Development Processes

Introduction

In this sub-section of the Cybersecurity Handbook, the individual tasks in the respective product life phase are explained and the associated activities are described. This information is intended to support all persons involved in their daily development work. IEC 62443-4-1:2019 is decisive for the description of the individual activities listed.

When using the document, it should be taken into account that a cross-reference may have to be taken into account in the individual steps. In addition, measures can already be available through instructions in the underlying development process definitions.

Overview of product development or product life cycle phases



It is important to take into account that measures in the course of development can have an impact on previous phases and/or measures. In addition to the existing innovation process and the agile development process of "ifm software gmbh", activities that go beyond the series phase are described. This includes monitoring the items for possible new threats and vulnerabilities, as well as providing information for secure disposal.

All individual activities described here must be carried out as part of product development and over the expected life period (security plan)

Organizational / Project-Specific

Requirements and management

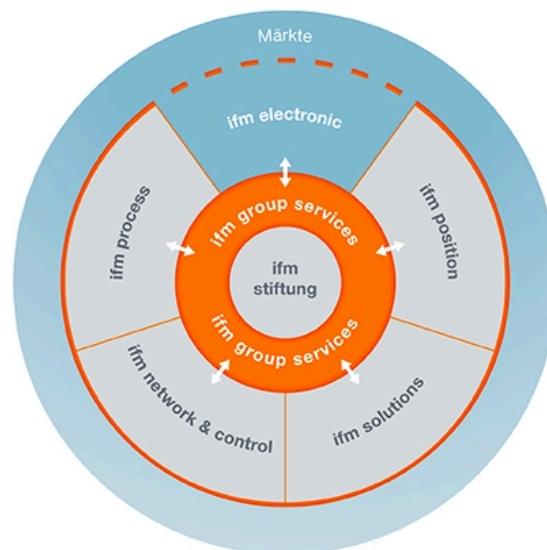
Development process

Regarding the quality of the products, ifm ecomatic explains in the Quality Management Handout:

"Quality planning takes into account the necessary processes that are required to meet customer requirements and secures them by means of a QM plan at defined stopping points (milestones, gates). Product Security has the highest priority."

(Source: ifm ecomatic Quality Management Handout, as of 30.03.2021)

The QM system of ifm ecomatic gmbh is ISO 9001 : 2015 certified. The last audit confirmed the QM system, and the certification is valid until 2024.



Business Purpose: ifm group services gmbh

Details to the business purposes are available within the ifm knowledge network, see [ifm group services gmbh](#) .

Within the ifm Group, central services are provided by the "ifm group services". These services are determined and specified by the business mandate of ["ifm group services"](#) and the ["context of the ifm group services organization"](#).

Identification of responsibilities

In accordance with the specifications of the PjM manual and the requirements of functional safety, special roles must be defined in project planning.

In addition to the project-specific roles, an additional Cybersecurity Engineer (CSE) is required for the requirements of Cybersecurity. A detailed description of the role and responsibilities is given in the role definition within the Management System. By demonstrating the appropriate competencies, every employee can take on the role of CSE, or the function can also be filled in combination with other roles.

The overall responsibility for compliance with the measures and the implementation of the necessary Cybersecurity functions lies with the project-specific Cybersecurity manager (CSM).

Identification of applicability

The labelling of applicability is determined on the basis of various criteria. The following criteria determine the extent to which Cybersecurity must be taken into account in the project or product:

- On the definition and determination of the requirements relevant to authorization
- Predefined decision trees for predefined policies

In case of doubt, applicability is presumed. The definition is based on the results of the threat or risk analysis.

The delimitation of activities or the complete exclusion of Cybersecurity must be documented by the product manager without any doubt. Based on this, there is no further consideration of the following requirements.

- ✚ Taking into account the current developments in the field of Cybersecurity requirements, decision trees are considered for marking applicability.

Cybersecurity expertise

The project participants are appointed by the supervisors of the individual departments/teams for the project. Supervisors are responsible for ensuring that the designated persons have the competence and qualifications to carry out the tasks assigned to them in the project. The qualification should be recognizable from the person's personnel  Schulungskonzept.pdf , training, activities.

Training courses from our external training partner are regularly offered via the central training platform. The content is updated as necessary and adapted to the respective division when executed, if possible in terms of content. Schulungskonzept.pdf. In addition, each division or person is free to independently build up and further develop the necessary specialist expertise.

Process containment

The project documentation specifies which changes to the life cycle phases are taken into account (additional or omitted phases) based on the project type (new development or modification). These adjustments must be justified and validated by the Cybersecurity expert. In case of doubt, the support of the Cybersecurity Manager can be called in.

File integrity

The integrity of all artifacts (scripts, executable files and other important files) of the development project or product is ensured by technical measures. Continuous tracking is provided in the documentation and the development-supporting tools.

IT security of the development environment

The employee responsible for the project has the task of ensuring the IT security of the development environment. For this purpose, the ifm Group relies on an IT security management system in accordance with ISO 27001. This includes organizational IT security guidelines, but also guidelines for handling hardware. → [General Directive on Information Security](#). Responsible for the operation and maintenance of the IT security concept is the "ifm group services"; the respective division is responsible for implementing the measures.

Private Key Monitoring

Additional security mechanisms must be provided for the protection of key material (private keys). Since private keys are the source of trust for all signatures, they must be specially protected and access regulated.

The administrative management of the code signing environment is the responsibility of the specialist department "Global IT Business Services Engineering Services". A corresponding service request can be created for the use of the signing interface. Deploying and managing the source code signing service is not part of this guide.

Cybersecurity Requirements of Externally Deployed Components

If the development of products is distributed among several parties, they are jointly responsible for meeting the requirements of the Cybersecurity lifecycle. The planning, execution and documentation must be carried out as if it corresponds to an in-house development. The exchange of information and the clear allocation of responsibilities are the goal of existence. External suppliers and service providers must be recorded in the development documentation

and a project-specific Development Interface Agreement (DIA) between both parties is required. The DIA shows which Cybersecurity-specific requirements are the responsibility of which party. Due to the different tasks, the required competence of the respective suppliers and service providers is defined / shown within the scope of the task (entry of the competence as "*) task-specific determination"). External suppliers and service providers provide people who work on their tasks under the same conditions as ifm employees. When selecting, assessing and continuously evaluating suppliers, the procedure "Selection, Assessment, Ongoing Evaluation of Suppliers" in the ifm QM system must be observed.

Customer-specific components from third-party suppliers

see "Cybersecurity Requirements of Externally Deployed Components". In addition to the requirements, it must be ensured that all necessary information is checked and handed over at the end of the order.

Assessing and addressing security-related issues

Before projects are completed, all required security measures must have been implemented. If it is absolutely necessary that security requirements cannot be implemented, a risk assessment must be carried out to determine whether a) the risk is accepted or b) other countermeasures must be taken into account for secure operation. The assessment and treatment of Security-related issues was carried out in coordination with the project manager and CSE. Problems must be considered at least in the following phases:

- requirements (see Practice 2 – Specification of security requirements);
- secure by design (see Practice 3 – Secure by design);
- implementation (see Practice 4 – Secure implementation);
- verification/validation (see Practice 5 – Security verification and validation testing); and
- defect management (Practice 6 – Management of security-related issues)

In accordance with IEC 61010 Annex J Section 2, the possible sequence of vulnerability treatment must be maintained.

Process Verification

A process must be in place to demonstrate that all applicable Security-related processes required by this specification (see Process Containment) have been completed prior to product release, and to have records documenting the completion of each process.

Continuous improvement

The main objective of the ifm electronic group of companies is:

"Growing up successfully in safety" [...]

To achieve this goal, the ifm Group will create or meet the following requirements:

Determination and fulfilment of customer, legal and official requirements in accordance with the current state of the art, in particular for Cybersecurity requirements for stationary automation products and products for vehicle use in accordance with road traffic law of the Federal Motor Transport Authority. This applies to wired and wireless communication products.

[...] Continuous improvement and further development of internal processes and increasing the effectiveness of the management system. [...]"

In addition, the following activities are part of the continuous improvement:

- Improvement of the vulnerability database
- Participation in conferences, committees, trade fairs with a focus on IT/OT security and Secure Development Lifecycle (SDLC)
- Conduct internal SDLC conferences to share expertise and innovation
- Perform audits using manual and automated security audit tools
- Development of test and inspection tools
- Continuous training and development of employees

Product Cybersecurity Lifecycle

The product (Security) life cycle describes the phases that a product goes through from initiation to development, commissioning and decommissioning. The product development phases typical of products of the ifm Group are described as part of the ifm innovation process. In the case of new development, the entire life cycle defined there is relevant, but can be adapted ("tailoring"). For modifications, the life cycle must be adapted to the specific project, depending on the scope and weight of the modification. The scope of the project-specific life cycle is defined in the modification specification.

Both platform development and the specific product development of individual derivatives go through the product life cycle as described below.

- Cybersecurity-relevant coordination must be documented throughout the entire development process. All appointments, in person or virtually, must be documented and tracked.

A template for the minutes of Cybersecurity-related meetings can be found here: [Templ
ate meeting minute for cybersecurity-related topics in the development process](#)

Design phase

Cybersecurity environment of the product

On the basis of the product properties documented in the specifications, the required security environment is defined. This determines the environment in which the product is operated and thus which security requirements the product must meet. Furthermore, the extent to which physical security measures are necessary or measures must be supplemented by the integrator or operator is documented.

The following factors must be taken into account:

- The place in the enterprise topology. This is where the Purdue model or the SCADA pyramid can be helpful
- Can physical security measures help protect the item? This includes, for example, whether the item is operated in a secure customer environment
- Is there a customer's security concept that can be used? Has a segmentation firewall been installed by the customer?

This also includes the consideration of necessary or prescribed qualified tools for use by the user, as well as the connection of the product to other products as a "system component" ("system concept").

All information on the Cybersecurity environment of the product must be documented in the requirement specification.

Result documents	Product concept catalogue
Requirement	Product concept catalogue
Verification	Review of specification documents (overview of product Security requirements)
Tool(s)	Polarion, export to .pdf
Responsible	R: Product Manager

Threatmodeling

Based on the customer's requirements in combination with the identified security environment, a threat model for the product is created. The threat model is based on the architectural planning of the article. By defining the trust boundaries, the system under consideration is limited to which the threat model is applied.

Result documents	Threat Analysis
Requirement	Product concept catalogue
Verification	Review of specification documents (overview of product security requirements, CRS (Cybersecurity Requirement specification))
Tool(s)	Polarion, Threat Analysis , Export to .pdf
Responsible	R: Product Security Engineer, C: technical Management

Cybersecurity requirements for the product

The vulnerabilities identified in the threat analysis are qualified using the risk analysis. The measures determined from the risk analysis are incorporated into the system specification.

The assessment of the risks of individual threats should be carried out in accordance with DIN EN 61010 or equivalent.

-  The following prioritization must be observed when treating risks:
- Eliminate or reduce risk (intrinsically secure design or construction)
 - Defining necessary protective measures with regard to risks that cannot be eliminated (protective device)
 - Providing information to users (security information)

The assessment of the threats related to your risks and their treatment must be included in the technical documentation without contradiction.

All requirements must be labeled according to the label policy, see [Definition of labels for activities in the development process related to Cybersecurity](#)

Result documents	Part of the system specification
Requirement	Threat analysis, risk register
Verification	Review of specification documents (overview of product Security requirements)
Tool(s)	Polarion, Threat Analysis , Export to .pdf

Responsible	R: technical Management, C: Product Security Engineer
-------------	---

Requirements for the Cybersecurity environment of the product

When selecting suitable measures to minimize risk, requirements for the environment of the product may be necessary or necessary. This could be due to a lack of hardware resources or software limitations. In addition, external requirements may be necessary to fulfill a function of the item (e.g., external storage of log information or external login services). These requirements must be documented and approved after consultation with the PM. Proof of the requirements for the security environment of the product is recorded in the customer documentation (see "Measures of the Defense-in-Depth Concept to Be Expected from the Environment").

The combination of the product's own functions and the Cybersecurity environment define the possible security level of the product (SL-x).

Result documents	Part of the system specification, part of customer documentation
Requirement	System specification, risk register
Verification	Review of specification documents (overview of product Security requirements)
Tool(s)	Polarion, Threat Analysis , Export to .pdf
Responsible	R: technical Management, C: Product Security Engineer

Overview of Cybersecurity requirements

All identified Cybersecurity requirements for the product must be checked and verified for validity, compliance and consistency in combination with threat analysis. Each of the following disciplines represented must be involved in the process:

- System architect/developer (those who implement the requirements)
- Auditors (those who will prove that the requirements have been met)
- Customer representatives (such as sales, marketing, product management, or customer service)
- Security Consultant (Cybersecurity Expert or Cybersecurity Manager)

Staff may be assigned to more than one specialty, with the exception of examiners, who must remain independent.

All requirements must be labeled according to the label policy, see [Definition of labels for activities in the development process related to Cybersecurity](#)

Result documents	verified system specification
Requirement	System Specification
Verification	Review of specification documents (overview of product Security requirements) (in terms of content, and against product requirements: traceability)
Tool(s)	Polarion, Threat Analysis , Export to .pdf
Responsible	R: technical Management

Development and testing

Principles for a secure design

Each interface of the product, including physical and logical interfaces, must be labeled and described with the following details:

1. an indication of whether the interface is accessible from the outside (from other products) or from the inside (from other components of the product or service), or both;
2. Cybersecurity impact of the product's Cybersecurity environment (see Section 6) on the external interface;
3. possible users of the interface and the objects of protection that can be accessed through it (directly or indirectly);
4. a determination of whether access to the interface crosses a trust boundary;
5. Cybersecurity considerations, assumptions and/or conditions related to the use of the interface within the Cybersecurity environment of the product, including applicable threats;
6. the Cybersecurity roles, authorizations/rights and access authorizations required for the use of the interface and for access to the protected objects specified in 3. above;
7. the Cybersecurity capabilities and/or compensation mechanisms for the protection of the interface and the objects of protection defined in c) above, including validation of both inputs and outputs and error handling;

8. the use of third-party products to implement the interface and its capabilities with regard to Cybersecurity;
9. documentation describing how to use the interface when it is accessible from the outside;
and
10. A description of how the draft mitigates the threats flagged in the threat model:

Result documents	Part of the system architecture
Requirement	System Specification
Verification	Review of the design review
Tool(s)	Polarion
Responsible	R: Development, C: System architect, Cybersecurity engineer

Design of a Defense-in-Depth Concept

When developing security solutions, it must be taken into account that the implementation of tiered functions is taken into account. This means that, for example, a connection-oriented connection protocol (TCP/http) with transport encryption (TLS) and then user authentication including authorization secures access to resources from the outside.

The aim is to implement a staggered security concept to protect the device in the event of a function being compromised by further, underlying layers.

Result documents	Part of the system architecture
Requirement	System Specification
Verification	Review of the design review
Tool(s)	Polarion
Responsible	R: Development, C: System architect, Cybersecurity engineer

Cybersecurity Design Review

Examination of the entire security design including:

- Security requirements (see section 6) that have not been sufficiently addressed by design
- Threats and their ability to exploit product interfaces, trust boundaries, and assets

- Identification of secure design practices (see "Secured Design Best Practices") that have not been followed

All Security-related issues must be tracked to closure.

Result documents	System architecture
Requirement	System specification, system architecture, threat analysis, risk analysis
Verification	Cybersecurity Design Review
Tool(s)	Polarion
Responsible	R: Development, C: System architect, Cybersecurity engineer

Assigning requirements, including security requirements, is part of typical design processes

The characterization of threats and their ability to exploit interfaces is often referred to as threat modeling

Secured Design Best Practices

The following basic principles must be taken into account in the draft/design phase:

- the application of proven Security components/designs
- the economic efficiency of the mechanism
- the use of secured design patterns
- Reducing the attack surface
- the documentation of all trust boundaries as part of the design
- removing debug connectors, debug connector strips, and traces on printed circuit boards used in development from the manufacturing hardware or documenting their presence and the need to protect them against unauthorized access.

Result documents	System architecture
Requirement	none
Verification	Security Design Review
Tool(s)	Polarion

Responsible	R: Test Manager, Delevopment , Cybersecurity engineer, System architect,
-------------	--

Verified Implementation

All security functions based on the requirements must be reviewed. The following tests must be carried out:

- Ensuring that coding standards have been met.
- A static code analysis to identify errors in the source code
- Determining that all implementations are traceable and valid.

Result documents	Test result
Requirement	Requirements definition
Verification	
Tool(s)	Polarion
Responsible	R: Test Manager, Delevopment , Cybersecurity engineer, System architect,

 Type of check: Static code analysis

Independence of the auditor: none

Coding standards for Cybersecurity

Basic coding guidelines are adhered to as part of the development work.

Coding standards and standards are checked for topicality and applicability at the start of the project and adapted if necessary. It is important to check that the standards are applicable to the development environment.

Result documents	Test result
Requirement	Requirements definition
Verification	
Tool(s)	Polarion
Responsible	R: Test Manager, Delevopment , Cybersecurity engineer, System architect,

Examination of Cybersecurity requirements

When reviewing the security requirements, it must be ensured that all necessary measures of the specifications and the design review have been taken into account and properly implemented. This includes checks of the individual functions and also of the entire security-in-depth functionality.

Result documents	Test result
Requirement	Requirements definition
Verification	
Tool(s)	Polarion
Responsible	R: Test Manager, Development , Cybersecurity engineer, System architect,

⚠ Type of audit: Audit of Cybersecurity requirements

Auditor independence: Security specialist from another department/division or member of quality assurance

Threat mitigation testing

When auditing threat mitigation, it is important to ensure that all the results of the threat analysis have been addressed and effectively implemented.

Result documents	Test result
Requirement	Requirements definition
Verification	
Tool(s)	Polarion
Responsible	R: Test Manager, Development , Cybersecurity engineer, System architect,

⚠ Scan type: Threat mitigation check

Auditor independence: Security specialist from another department/division or member of quality assurance

Vulnerability Testing

All products must undergo various security tests before being placed on the market, which focus on identifying and characterizing potential security vulnerabilities in the product. Where applicable, the following checks should be carried out:

- Analysis of software composition

Software composition analysis of all binary executables, including embedded firmware, supplied by the supplier and installed for a product. This analysis is designed to detect at least the following types of problems:

known vulnerabilities in the product software components;

linking to vulnerable libraries;

security rule violations; and

compiler settings that can lead to vulnerabilities;

This check is performed by using the "Software Composition Analysis" within the build pipeline or as an output of the compiler used.

- Attack surface analysis

It must be ensured that all exposed interfaces are documented and checked for known vulnerabilities, insecure access controls or permission violations.

- Scan for known vulnerabilities

It must be ensured that all exposed interfaces are free of known vulnerabilities.

 This type of check can be done by using network-based vulnerability scanners.

- Examination of abuse cases

A comprehensive input check must ensure that no faulty or abusive security problems can be caused. These tests are performed on all interfaces and protocols.

- Dynamic verification within the runtime environment

Optional: dynamic code analysis during runtime

Result documents	Test result
Requirement	Requirements definition
Verification	

Tool(s)	Polarion
Responsible	R: Test Manager, Development , Cybersecurity engineer, System architect,

⚠ Type of audit: Vulnerability review

Auditor independence: Independent person; must not be the developer

Penetration Testing

Optional: The penetration test is carried out on the basis of the targeted security level. As a rule, the inspection is automated with industry-standard tools and moderate effort. For components whose intended use is to be used at level > 3 of the Purdue Model, it is recommended to search for vulnerabilities in a more targeted and active manner (definition: medium motivation, selected tools, high expertise). Manufacturer internal information may also be used here if required.

If a high or certified security level is required, the intrusion test must be carried out by a qualified external body. The means and resources required for this purpose must be taken into account in the project planning.

Result documents	Test result
Requirement	Requirements definition
Verification	
Tool(s)	Polarion
Responsible	R: Test Manager, Development , Cybersecurity engineer, System architect,

📌 The need for a penetration test and the associated effort should be determined based on positioning in the Purdue Model, communication capability, and exposure.

⚠ Type of test: Penetration test

Independence of the auditor: Security specialist of another department/division or member of quality assurance or, independent organization, or external third party

Independence of the tester

For the examination of security measures, independence of the person must be guaranteed in accordance with the nature of the examination.

Test type	Reference	Level of independence
Security requirements testing	SVV-1 - Security requirements testing	Independent department
Threat mitigation testing	SVV-2 - Threat mitigation testing	Independent department
Abuse case testing	SVV-3 - Vulnerability testing	Independent person
Static code analysis	SI-1 - Security implementation review	None
Attack surface analysis	SVV-3 - Vulnerability testing	Independent person
Known vulnerability scanning	SVV-3 - Vulnerability testing	Independent person
Software composition analysis	SVV-3 - Vulnerability testing	None
Penetration testing	SVV-4 - Penetration testing	Independent department or organization

Tabelle 1: Independence of testers

Explanation of “Level of independence:

None: No independence required. The check can be done by the developer.

Independent person: The person conducting the audit cannot be one of the product developers.

Independent department: The person conducting the audit cannot submit a report to the same direct supervisor that product developers report to. Alternatively, she could be a member of a quality assurance (QA) department.

Independent organization: The person conducting the audit cannot be part of the same organization that any product developer belongs to. An organization can be a separate legal entity, a division of a company, or a department of a company that reports to another executive such as a director or to a similar level.

Suitability of Cybersecurity updates

All security updates provided must not affect the intended use of the product or have an impact on other security functions. In addition, it must be ensured that there are no legal restrictions on the use of the updates.

Documentation of Cybersecurity updates

The documentation of security updates must contain at least the following information:

- Uniquely identify the product to which the security patch applies
- Instructions on how to apply approved patches manually or using an automated process
- A description of all the effects that the application of the patch will have on the product, including a reboot
- Instructions on how to prove that an approved patch has been applied
- Risks arising from the failure to apply the patch and mediations that can be used for patches that are not approved or used by the operator.

This information is intended to help the customer determine the criticality of the update. Furthermore, this information is helpful in customer-side change management.

Documentation of Cybersecurity updates for dependent components or operating systems

The update documentation must include information about how dependent components or operating systems are affected. This information gives operators the opportunity to assess and treat possible influences.

 e.g. a vulnerability may require an adjustment of communication protocols or the necessary software components provided by the operating system may have to be replaced.

Delivery of Cybersecurity updates

No separate measures need to be taken for the delivery of security updates. The provision is carried out via the control process via the Software Download Center within the ifm website.

Timely delivery of Cybersecurity patches

According to the security strategy, it is essential that information about upcoming security updates is made available to our customers as soon as possible. Information as early as possible enables customers to plan the necessary update in their own maintenance processes. Taking into account the criticality, the scope of the articles affected and possible compensatory measures, updates should be provided. The determination of these periods is determined in connection with the development cycles. A description of the criticality can be found in the

vulnerability management process Area 4: [Product Security and Incident response process | Vulnerability and incident remediation \(Area 4\)](#).

Provisioning

Cybersecurity Policies

As part of the user documentation, information for the product must be available to support installation, operation, and maintenance. This information is used to help inform how to integrate, configure, and maintain the product's defense-in-depth strategy in accordance with its Cybersecurity environment. The following information must be included in the user documentation:

- Cybersecurity capabilities implemented by the product
- what measures must be taken during the first commissioning and throughout the life of the product with digital elements to ensure its secure use
- How changes to the product with digital elements can affect data security
- How to install security-related updates
- how to secure decommission the product with digital elements and how to securely remove user data
- how the integrator can meet the basic Cybersecurity requirements and technical documentation requirements if the product with digital elements is intended for integration with other products with digital elements

Result documents	Part of the operating instructions Security White Paper
Prerequisite	Product Requirements System Specification
Verification	Review of further development documentation
Tool(s)	Polarion, authoring tool
Responsible	R: Product Management, C: technical Management, Development

Review of documentation

The completeness of the security documentation must be checked for correctness and completeness

Result documents	Part of the operating instructions Security White Paper
Requirement	Product Requirements System Specification
Verification	Review of further development documentation
Tool(s)	Polarion, authoring tool
Responsible	R: Product Management, C: technical Management

Operation, continuous monitoring and maintenance

The monitoring of the component after it has been placed on the market is carried out centrally via the PSIRT of ifm "Global Security Services".

Initiation of Periodic Review

Due to new vulnerabilities, attack methods, or threat actors, it is essential that the threat analysis be reviewed. This review must be conducted at least annually, starting from the initial market release, even if there have been no technical changes to the product. The review must be documented in the technical documentation and carried out by the responsible employee assigned to the product.

-  This activity is initiated by the "Global Security Services" Department with the ifm group services. The responsible technical managers will be informed by mail to perform the tasks.

Result documents	Part of the technical documentation
Requirement	Threat- and Risk-Analyses technical documentation Threat-Katalogue and databases
Verification	Review and update Threat- and Risk Analyses
Tool(s)	
Responsible	C: Global Security Services, R: technical Management

Mapping table for product life cycle and standards

Product Lifecycle	62443-4-1 Activity	ISO/SAE 21434 Sub-Activity	ISO/SAE 21434 Work products	Support-Process
Organisation Pre-Phase	SM-1: Development process	Management systems	[WP-05-03] Evidence of the organization's management systems	
Organisation Pre-Phase		Cybersecurity governance	[WP-05-01] Cybersecurity policy, rules and processes	
Organisation Pre-Phase	SM-4: Security expertise	Cybersecurity culture	[WP-05-01] Cybersecurity policy, rules and processes [WP-05-02] Evidence of competence management, awareness management and continuous improvement	
Organisation Pre-Phase		Information sharing	[WP-05-01] Cybersecurity policy, rules and processes	
Organisation Pre-Phase	SM-2: Identification of responsibilities	Cybersecurity responsibilities	[WP-06-01] Cybersecurity plan	
Organisation Pre-Phase	SM-3: Identification of applicability	Cybersecurity planning	[WP-06-01] Cybersecurity plan	
Organisation Pre-Phase	SM-5: Process scoping	Tailoring Reuse	[WP-06-01] Cybersecurity plan	

Organisation Pre-Phase	SM-6: File integrity			
Organisation Pre-Phase	SM-7: Development environment security	Tool management Information security management	[WP-05-04] Evidence of tool management	
Organisation Pre-Phase	SM-8: Controls for private keys		[WP-05-04] Evidence of tool management	
Organisation Pre-Phase	SM-9: Security requirements for externally provided components		[WP-07-01] Cybersecurity interface agreement	
Organisation Pre-Phase	SM-10: Custom developed components from third-party suppliers		[WP-07-01] Cybersecurity interface agreement	
Organisation Pre-Phase	SM-11: Assessing and addressing security-related issues			
Organisation Pre-Phase	SM-12: Process verification	Organizational Cybersecurity audit	[WP-05-05] Organizational Cybersecurity audit report [WP-06-03] Cybersecurity assessment report	
Organisation Pre-Phase	SM-13: Continuous improvement			
Concept Phase	SR-1: Product security context	Item definition	[WP-09-01] Item definition	

Concept Phase	SR-2: Threat model	Cybersecurity goals	[WP-09-02] TARA [WP-09-03] Cybersecurity goals [WP-09-04] Cybersecurity claims	
Concept Phase	SR-3: Product security requirements	Cybersecurity concept	[WP-09-06] Cybersecurity concept	
Concept Phase	SR-4: Product security requirements content	Component out-of-context Off-the-shelf component	[WP-06-01] Cybersecurity plan	
Concept Phase	SR-5: Security requirements review	Cybersecurity case Cybersecurity assessment Release for post-development	[WP-06-02] Cybersecurity case [WP-06-03] Cybersecurity assessment report [WP-06-04] Release for post-development report [WP-09-05] Verification report for Cybersecurity goals [WP-09-07] Verification report of Cybersecurity concept	
development & testing phase	SD-1: Secure design principles	Design	[WP-10-01] Cybersecurity specifications	
development & testing phase	SD-2: Defense in depth design	Design	[WP-10-02] Cybersecurity requirements for post-development	

development & testing phase	SD-3: Security design review	Design	[WP-10-04] Verification report for the Cybersecurity specifications	
development & testing phase	SD-4: Secure design best practices	Integration and verification	[WP-10-06] Integration and verification specification	
development & testing phase	SI-1: Security implementation review	Integration and verification Cybersecurity validation	[WP-10-07] Integration and verification report [WP-11-01] Validation report	
development & testing phase	SI-2: Secure coding standards	Design	[WP-10-03] Documentation of the modelling, design, or programming languages and coding guidelines	
		Cybersecurity incident response	[WP-13-01] Cybersecurity incident response plan	corrective measures
Operational phase	SUM-1: Security update qualification	Updates		
Operational phase	SUM-2: Security update documentation	Updates		
Operational phase	SUM-3: Dependent component or operating system security update documentation	Updates		
Operational phase	SUM-4: Security update delivery	Updates		

Operation al phase	SUM-5: Timely delivery of security patches	Updates		
developm ent & testing phase	SVV-1: Security requirements testing	Integration and verification	[WP-10-07] Integration and verification report	
developm ent & testing phase	SVV-2: Threat mitigation testing	Integration and verification	[WP-10-07] Integration and verification report	
developm ent & testing phase	SVV-3: Vulnerability testing	Integration and verification	[WP-10-07] Integration and verification report	
developm ent & testing phase	SVV-4: Penetration testing	Integration and verification	[WP-10-07] Integration and verification report	
developm ent & testing phase	SVV-5: Independence of testers			
Deployme nt phase	SG-1: Product defense in depth			
Deployme nt phase	SG-2: Defense in depth measures expected in the environment			
Deployme nt phase	SG-3: Security hardening guidelines			

Deployment phase	SG-4: Secure disposal guidelines			
Deployment phase	SG-5: Secure operation guidelines			
Deployment phase	SG-6: Account management guidelines			
Deployment phase	SG-7: Documentation review			
Operational phase	DM-1: Receiving notifications of security-related issues	Cybersecurity monitoring	[WP-08-01] Sources for Cybersecurity information [WP-08-02] Triggers [WP-08-03] Cybersecurity events	PSIRT
Operational phase	DM-2: Reviewing security-related issues			PSIRT
Operational phase	DM-3: Assessing security-related issues	Cybersecurity event evaluation	[WP-08-04] Weaknesses from Cybersecurity events	PSIRT
Operational phase	DM-4: Addressing security-related issues	Vulnerability analysis	[WP-08-05] Vulnerability analysis	PSIRT
Operational phase	DM-5: Disclosing security-related issues			PSIRT
Operational phase	DM-6: Periodic review of security defect management practice	Vulnerability management	[WP-08-06] Evidence of managed vulnerabilities	PSIRT

List of abbreviations

Abbreviation	Meaning	Description
US	united states	
E2E	End to End	
IEC	International Electrotechnical Commission	
IN	European Standard	
ISO	International Organisation for Standardization	
SAE	Society of Automotive Engineers	
ifm	Engineering Society for Measurement Technology	
TSC	technical steering committee	
SWG	Subworking group	
DMO	Development management office	
PjM	Project Management	
SCADA	Supervisory Control and Data Acquisition	
QM	Quality	
CRAYFISH	Accountability model	
CSE	Cybersecurity engineer	
CSM	Cybersecurity Manager	
CSMS	Cybersecurity management system	
IT	Information technology	
HSM	Hardware security module	
I&D	Verification and Validation	
DAY	Development Interface Agreement	

SPB	Support Process	
OT	operational technology	
SDLC	Software development lifecycle	

Änderungs

Version	Datum	Kommentar
Aktuelle Version (v. 8)	Okt. 02, 2025 09:52	Matthias Schmidt
v. 7	Sept. 02, 2025 06:44	Matthias Schmidt
v. 6	Aug. 20, 2025 10:10	Matthias Schmidt
v. 5	Aug. 20, 2025 10:08	Matthias Schmidt
v. 4	Aug. 20, 2025 09:45	Matthias Schmidt
v. 3	Aug. 20, 2025 09:43	Matthias Schmidt
v. 2	Aug. 20, 2025 06:32	Matthias Schmidt
v. 1	Aug. 08, 2025 11:49	Matthias Schmidt